



OWASP stands for the **Open Worldwide Application Security Project**, which is a global non-profit organization focused on improving software security. OWASP which was formerly known as “**Open Web Application Security Project**” is an online community that publishes and provides free and open resources like articles, methodologies, documentation, tools, and technologies covering various domains targeting IoT (Internet Of Things), System’s software and Web application security.

OWASP was started by Mark Curphey on September 9, 2001 and is supported and backed by “**OWASP Foundation**”, a **501(c)(3)**– “*US Internal Revenue Code that allows for federal tax exemption of non-profit organizations that meet the code's requirements*” - non-profit organization in the US established in 2004.

The Mission of OWASP is to make the software’s security visible and is dedicated to improving the software security and make it accessible to everyone through awareness, tools, and community collaboration.



Overview and introduction to OWASP:

OWASP provides the OWASP Top 10 which is a globally recognized web application security standard which outlines the most critical web application security risks. OWASP first published the top 10 in the year 2003 and is regularly updated to identify and highlight some of the most critical risks an organization faces.

The OWASP Top 10 is a collated list of the most critical security risks that web applications faces, as reviewed and validated by various security experts round the globe. This OWASP Top 10 serves as a guideline for organizations in application/software development field, developers, application security team and others who are responsible for ensuring the security of web applications and secure software development to produce a vulnerability and risk free application.

The OWASP Top 10 is a standard awareness document for developers and web application security. It represents a broad consensus about the most critical security risks to web applications. Below are the OWASP top 10 Web Application Security Risks:

1. A01:2021-Broken Access Control
2. A02:2021-Cryptographic Failures
3. A03:2021-Injection
4. A04:2021-Insecure Design

5. A05:2021-Security Misconfiguration
6. A06:2021-Vulnerable and Outdated Components
7. A07:2021-Identification and Authentication Failures
8. A08:2021-Software and Data Integrity Failures
9. A09:2021-Security Logging and Monitoring Failures
10. A10:2021-Server-Side Request Forgery

Using the OWASP Top 10 is perhaps the most effective first step in changing the software development culture in an organization to produces more secure code.



The OWASP Top 10 list of web application security threats is derived based on the contribution from security experts around the world which is reviewed and finalized with the consensus from all the contributors and security experts. The top 10 risks are ranked basis on multiple factors including how often each of these top 10 security vulnerability occurs and the severity and magnitude of its potential impact.

OWASP calculate the average exploit and impact scores following the below methodology to derive the top 10:

All the CVEs (Common Vulnerabilities and Exposures) are grouped with CVSS (Common Vulnerability Scoring System) scores by CWE (Common Weakness Enumeration) and

weighted both exploit and impact scored by the percentage of the population that had CVSSv3 (Common Vulnerability Scoring System Version 3) + the remaining population of CVSSv2 (Common Vulnerability Scoring System Version 2) scores to get an overall average. These averages are then mapped to the CWEs in the dataset to use as Exploit and (Technical) Impact scoring for the other half of the risk equation.

Categorization of OWASP Top 10:

The OWASP Top 10 categorization is based on data from global security experts, real-world vulnerability data, and industry surveys. Risks are ranked by factors such as prevalence, exploitability, detectability, and potential business impact. This collaborative process ensures the list reflects the most critical and widespread web application security threats faced by organizations worldwide.

- **Vulnerabilities Collection:** OWASP solicits data from security professionals and organizations about vulnerabilities found in web applications.
- **Categorization of Vulnerabilities:** Submitted vulnerabilities are analyzed and categorized based on its root cause and the impact.
- **Prioritization of Risk:** Risk prioritization based on the vulnerabilities and exploits and lastly selection of the Top 10.